Universidad Nacional Autónoma de México
Facultad de Ingeniería
División de Ingeniería Eléctrica

Sistemas Operativos

Exposición - Vulnerabilidad *Eternal Blue* de Windows NT

Semestre 2026 - 2
Profesor: Dr. Gunnar Eyal Wolf Iszaevich
Grupo: 07
Integrantes:

- Monroy Tapia Jesús Alejandro
- Ponce de León Reyes Bruno

Fecha de entrega: 05 de marzo de 2026

Índice

1. Introducción.....3
1.1 Diseño de Windows NT.....3
1.2 El protocolo SMB.....4
1.3 Rendimiento.....4
2. Arquitectura del sistema operativo.....5
2.1. Modelo arquitectónico.....5
2.1.1. Modo Usuario.....5
2.1.2. Modo Kernel.....6
2.1.3. Gestión de memoria.....6
2.1.4. Sistema de entrada y salida (E/S).....6
3. Estructura de la vulnerabilidad.....6
4. Explotación de la vulnerabilidad.....7
4.1 Manipulación del montón.....7
4.2 Sobreescritura de estructuras críticas.....7
4.3 Desvío del flujo de ejecución (RCE).....7
4.4 Escalada de privilegios.....8
5. Mitigación y vigencia.....8
5.1. Medidas de seguridad.....8
5.2. Impacto en la actualidad.....8
6. Conclusiones.....9
6.1 Resumen del fallo.....9
6.2 Lecciones aprendidas.....9
Bibliografía:.....10

1. Introducción

En 1993 Microsoft lanza Windows New Technology o simplemente Windows NT. Un nuevo kernel para el sistema operativo Windows, teniendo la característica principal de ya no depender de MS-DOS. Windows NT convierte a los sistemas operativos Windows en sistemas operativos propios y ya no simples entornos de escritorio dependientes de MS-DOS, además de ofrecer nuevas características como la multitarea apropiativa y el sistema de archivos NTFS.

El primer Windows con este kernel fue Windows 3.1 NT lanzado en 1993, fue la primera versión de la familia de Windows NT, pensada para estaciones de trabajo y servidores de negocios, tras su lanzamiento Windows 3.1 NT fue un éxito para Microsoft por lo que decidieron lanzar los siguientes años actualizaciones consecutivas de Windows NT, siendo estás, Windows NT 3.5 (1994), Windows NT 3.51 (1995) y Windows NT 4.0 (1996).

Windows NT marca un después claro en la historia de Microsoft de los sistemas operativos Windows puesto que sus posteriores productos estarían basados en este mismo kernel con actualizaciones hechas en cada lanzamiento de una nueva versión del sistema operativo. Hoy día el kernel de Windows NT sigue presente en las versiones más recientes de Windows por lo cuál es importante conocer su estructura y arquitectura del mismo para comprender también una de las vulnerabilidades más graves a que ha tenido Microsoft en su historia, *Eternal Blue,* una vulnerabilidad que afecta a gran parte de la familia Windows NT y que está catalogada con el CVE-2017-0144.

Para entender mejor entraremos a detalle en el diseño y arquitectura de Windows NT y como su diseño lo hacía propenso a esta vulnerabilidad.

1.1 Diseño de Windows NT

La familia de sistemas operativos Windows NT (New Technology), que sirve de base para todas las versiones modernas de Windows (desde XP y Windows 7 hasta Windows 11 y Windows Server), fue concebida con una **arquitectura de núcleo híbrido**. Este diseño busca un equilibrio entre el rendimiento y la estabilidad del sistema mediante una estricta separación de los espacios de memoria y los niveles de privilegio del procesador, comúnmente llamados anillos de protección (*Protection Rings*).

A nivel organizativo, el sistema operativo se divide fundamentalmente en dos áreas principales:

- **Modo Usuario (User Mode / Ring 3):** Es el entorno aislado donde se ejecutan las aplicaciones normales, los navegadores y la mayoría de los servicios del usuario. El código en este modo tiene un acceso muy restringido; no puede comunicarse directamente con el hardware ni acceder a la memoria de otros procesos. Si un

programa en Modo Usuario falla, el sistema operativo generalmente puede recuperarse sin problemas, cerrando únicamente la aplicación afectada.

- **Modo Núcleo (Kernel Mode / Ring 0):** Es el corazón del sistema operativo. Aquí residen el núcleo de Windows, la capa de abstracción de hardware (HAL), la gestión de memoria principal y los controladores de dispositivos (*drivers*). El código en esta capa tiene control total y absoluto sobre todo el sistema, la memoria física y el hardware. Un fallo crítico aquí provoca una caída total del sistema, conocida como la "Pantalla Azul de la Muerte" (BSOD)

1.2 El protocolo SMB

El protocolo Server Message Block (SMB) es un protocolo de red que permite compartir archivos, impresoras, y demás entre todos de una red de computadoras con un sistema operativo Windows comúnmente. Este protocolo pertenece a la capa de aplicación del modelo TCP/IP.

Este protocolo fue desarrollado originalmente por IBM, pero la versión más común y utilizada es la modificada por Microsoft para sus sistemas operativos. Aunque este protocolo ya estaba presente en los productos de Microsoft como Windows 95 y 98, no fue hasta Windows 2000 y con una modificación de Windows NT que se redefine la implementación de este protocolo por parte de Microsoft cambiandole el nombre a CIFS (Common Internet File System), esta implementación de SMB por parte de Microsoft incluye modificaciones que no son parte del protocolo SMB original desarrollado por IBM.

La mejora del protocolo SMB en Windows 2000 es relevante debido a que en versiones anteriores de Windows NT como Windows 4.0 NT no utilizaban TCP/IP para implementar la resolución de nombres de dominio, algo que con Windows 2000 cambia debido a que se utiliza una denominación DNS que permite a los protocolos TCP/IP compartir recursos SMB.

La vulnerabilidad *Eternal Blue* toma ventaja de un exploit supuestamente “creado” por la NSA que toma ventaja del protocolo SMB en su versión 1, implementado en sistemas operativos de la familia Windows NT.

1.3 Rendimiento

Como se mencionó anteriormente Windows NT funciona con dos modos, *Modo Usuario* y *Modo Núcleo o Kernel*, en Windows NT pasar datos entre estos dos modos es muy costoso en recursos de la CPU, ya que el procesador cambia de Ring 3 a Ring 0 y debe guardar los estados de los registros y cambiar las tablas de páginas de memoria y validar permisos.

Si SMB estuviera en *Modo Usuario* cada paquete de red tendría que viajar de la tarjeta de red, al Kernel, a la Aplicación de Usuario, Kernel y finalmente al Disco. Este camino

provocaría que Windows NT no fuera competitivo a nivel de Servidores. ¿Por qué? Windows NT no solo salió para el usuario de oficina o escritorio, sino que también se lanzó para Servidores con Windows NT Advanced.

Por esto mismo Microsoft opto que el procesamiento del protocolo SMB ocurriera dentro del espacio del núcleo, con el controlador *srv.sys*. Esto lo que otorga es que se gana un rendimiento de red extremadamente rápido debido a que no hay que hacer saltos innecesarios entre modos.

El problema de esto radicó en que se permitían que paquetes de red crudos y no confiables provenientes de internet y otras redes sean procesador por código que tiene privilegios sobre el sistema, esto es lo que se aprovecha la vulnerabilidad de *Eternal Blue.* Y como consecuencia el atacante no solo puede romper un código sino que puede sobreescribir la memoria del propio kernel del sistema.

Todos estos puntos sobre Windows NT y *Eternal Blue*, así como la explotación, remedio y vigencia de esta vulnerabilidad serán abordados en este trabajo para tener una mejor compresión sobre está y como decisiones de diseño en los sistemas operativos pueden afectar a millones de usuarios y cientos en empresas en el internet.

2. Arquitectura del sistema operativo

Windows NT (New Technology) cuenta con un kernel híbrido, combina los diseños de kernel monolítico y de microkernel, como consecuencia, es altamente modular y fué utilizado inicialmente por sistemas como Windows XP, Windows Vista, Windows 2000, entre otros.
Es la base de los sistemas modernos Windows 10 y Windows 11. A continuación, se mostrarán algunos de los componentes arquitectónicos más importantes del sistema.

2.1. Modelo arquitectónico

Este sistema introdujo avances como protección de memoria y soporte para multiprocesamiento simétrico (SMP). Originalmente estaba diseñado para funcionar en computadoras de un solo procesador como aquellas que utilizan multiprocesamiento simétrico. Cuenta con dos modos principales: *Modo Kernel* y *Modo Usuario*.

2.1.1. Modo Usuario

El modo usuario está encargado de la ejecución de aplicaciones y servicios sin el uso del acceso directo a los recursos del sistema. La ejecución de aplicaciones se realiza de forma aislada y opera con privilegios limitados. En caso de que una aplicación se interrumpa o sufra errores, ninguna de las otras aplicaciones o datos críticos del sistema operativo se verán afectados.

2.1.2. Modo Kernel

Este modo está enfocado al control del acceso a la planificación, priorización de hilos, gestión de memoria y principalmente la interacción con el hardware. Tiene acceso total al hardware y a los recursos de la computadora, lo que permite que realice operaciones críticas para el funcionamiento del sistema operativo.
Es el responsable de llevar a cabo la gestión de recursos, por lo que, los demás procesos en el sistema deben de pedirle mediante llamadas al sistema que realice las operaciones necesarias en caso de requerir dichos recursos.

2.1.3. Gestión de memoria

Tal como su nombre lo menciona, este es un componente encargado de gestionar la memoria disponible de la computadora, asegurándose de brindar acceso seguro y el uso eficiente de la misma. Para lograr esto, se enfoca en la asignación de memoria para cada proceso en el sistema, siempre buscando optimizar su uso y garantizar la estabilidad y el rendimiento del sistema.

2.1.4. Sistema de entrada y salida (E/S)

Sistema encargado de la comunicación entre aplicaciones y los dispositivos de hardware de la computadora. Funciona como un intermediario entre ambos, evitando así que las aplicaciones accedan directamente a los dispositivos, ofreciendo una comunicación segura y controlada.
El sistema E/S recibe peticiones del sistema de archivos y se encarga de realizar las llamadas específicas para los dispositivos.

3. Estructura de la vulnerabilidad

Al analizar *Eternal Blue*, se ha determinado que esta vulnerabilidad tiene lugar en el subsistema de entrada y salida (E/S), específicamente en el modo kernel y en el driver ***srv.sys*** que implementa el protocolo Server Message Block version 1 (SMBv1).

Server Message Block (SMB) es un protocolo de red empleado para el acceso a archivos, impresoras y otros recursos compartidos que se encuentran en una red. Este protocolo emplea el puerto 445 para permitir la comunicación en la red, es a partir de este que un atacante puede:
Enviar paquetes especialmente diseñados por SMB y posteriormente pasar por el sistema de entrada y salida (E/S), en donde se analiza la petición y se pasa al driver ***srv.sys***.
Al realizarse una mala validación de datos por parte de SMBv1, se produce un error en el manejo de memoria, específicamente un overflow en el buffer, lo que lleva al exploit a sobreescribir memoria y ejecutar código en modo kernel.

4. Explotación de la vulnerabilidad

Esta vulnerabilidad fue descubierta por la NSA de Estados Unidos, pero fue explotada de manera masiva hasta el 2017 mediante el ransomware de WannaCry que afectó cientos de computadoras con sistemas operativos Windows y sobre todo que tenían el protocolo de red SMB v1, el cuál tiene un error del cuál *Eternal Blue* puede aprovecharse, pero vamos a desmenuzar esto para entender mejor el funcionamiento de *Eternal Blue*

4.1 Manipulación del montón

En el kernel de Windows NT, la memoria se asigna dinámicamente en áreas llamadas *pools*. Antes de lanzar el ataque real, *Eternal Blue* necesita que la memoria esté organizada de una manera predecible.

El exploit envía una serie calculada de peticiones SMB legítimas para forzar al sistema a asignar y liberar bloques de memoria en el *Non-Paged Pool.*

Esta técnica, es conocida como *Pool Grooming* de memoria, crea "huecos" específicos. El atacante logra colocar un bloque de memoria vulnerable, que pronto se desbordará, ya que está exactamente contiguo a una estructura de datos crítica del sistema el *SRVNET*

4.2 Sobreescritura de estructuras críticas

Una vez que la memoria está alineada perfectamente, el exploit envía un paquete malicioso diseñado para desencadenar la vulnerabilidad principal, un desbordamiento de búfer orginado por un error de cálculo de enteros un *Integer Overflow.*

Al procesar una lista de FEA mal formada, la función *SrvOs2FeaListSizeToNt* calcula mal el tamaño necesario. Esto provoca que el sistema copie más datos de los que caben en el búfer asignado.

Como el búfer vulnerable se posicionó intencionalmente justo antes de la estructura *SRVNET*, el exceso de datos cae sobre esta estructura vecina. El atacante sobrescribe partes vitales de *SRVNET*, específicamente la lista de descriptores de memoria o sus punteros de función

4.3 Desvío del flujo de ejecución (RCE)

La corrupción de memoria que se hizo anteriormente es lo que permite al atacante tomar el control del procesador. El objetivo de sobrescribir la estructura *SRVNET* no es bloquear el sistema (lo cual causaría un pantallazo azul), sino redirigir sus acciones.

El atacante ya ha introducido su código malicioso, un programa conocido como *shellcode* en la memoria en paquetes anteriores. Al sobrescribir los punteros de la estructura *SRVNET*, modifica las instrucciones sobre "dónde debe ir el sistema a continuación".

Cuando el driver de SMB intenta usar la conexión *SRVNET* corrupta, lee el puntero modificado. En lugar de ejecutar la función legítima del kernel de Windows, el flujo de ejecución salta directamente a la dirección de memoria donde reside el *shellcode* del atacante.

4.4 Escalada de privilegios

En la mayoria de los ciberataques, lograr el RCE (Ejecución Remota de Código) te otorga permisos del usuario o servicio que fue vulnerado. Sin embargo con *Eternal Blue* es diferente y más crítico.

Dado que la vulnerabilidad reside en *srv.sys*, que es un driver del modo núcleo, el *shellcode* inyectado hereda automáticamente los privilegios de ese entorno.

No se requieren pasos adicionales para escalar los privilegios usando esta vulnerabilidad. El código se ejecuta bajo el contexto de *NT AUTHORITY\SYSTEM* que es el usuario con más privilegios en Windows NT. Desde este punto, el atacante tiene control absoluto sobre el sistema, permitiendo instalar la persistencia.

5. Mitigación y vigencia

Una vez que Eternal Blue fue descubierta, se tuvieron que tomar medidas con el fin de remediar la vulnerabilidad y evitar que esta pudiera ser explotada con fines maliciosos.
Principalmente, la solución que se le dió a esta vulnerabilidad fue aplicar el parche de Microsoft ***MS17–010***, lanzado en marzo de 2017. Este parche solventó la vulnerabilidad al evitar la ejecución remota de código (RCE) mediante la validación adecuada de peticiones en el protocolo SMBv1.

5.1. Medidas de seguridad

Una de las medidas aplicadas es desactivar SMBv1 o incluso bloquear el puerto 445 si estos no eran utilizados, el propósito era evitar que el protocolo pueda ser empleado para explotar la vulnerabilidad.
En general, para mantener un sistema protegido y libre de vulnerabilidades, una de las medidas de seguridad más importantes es siempre mantener el sistema actualizado, para que así se puedan aplicar parches de seguridad críticos que solucionan todo tipo de vulnerabilidades conforme se van detectando.

5.2. Impacto en la actualidad

Esta fue una vulnerabilidad muy grave debido a la popularidad de Windows, siendo hasta la actualidad uno de los sistemas operativos más utilizados a nivel global.

Dentro de los peligros está el robo o secuestro de datos, el acceso no autorizado a sistemas, ser víctima de espionaje, entre otras.
Desafortunadamente, esta vulnerabilidad aún puede estar presente y afectar principalmente a sistemas aún no actualizados. De igual forma, el uso de SMBv1 y configuraciones inseguras de red pueden exponer al sistema y ser un riesgo para la seguridad.

6. Conclusiones

6.1 Resumen del fallo

El núcleo de la vulnerabilidad *Eternal Blue* (CVE-2017-0144) radica en una falla crítica de diseño y validación dentro de la arquitectura del sistema operativo Windows, específicamente en la implementación del protocolo legado SMBv1.

Todo comienza con un error de *Intenger Overflow* en el driver kernel *srv.sys* al procesar una lista maliciosa de FEA. Este error de cálculo engaña al gestor de memoria del kernel, provocando un desbordamiento del búfer.

Mediante una meticulosa manipulación de la memoria (Pool Grooming), el atacante logra alinear los bloques para sobrescribir la estructura adyacente *SRVNET*. Esto desvía el flujo de ejecución hacia un shellcode previamente inyectado, otorgando ejecución remota de código (RCE) directa en Ring 0 (modo núcleo) con privilegios de *NT AUTHORITY\SYSTEM*, sin requerir interacción del usuario ni autenticación previa.

6.2 Lecciones aprendidas

El impacto global de EternalBlue, especialmente tras su automatización en los ataques de *ransomware* WannaCry y NotPetya, transformó las metodologías de seguridad a nivel mundial. Las lecciones abarcan desde la administración a bajo nivel hasta la arquitectura de redes.

La principal lección a nivel de organización de sistemas es la necesidad de auditar y deshabilitar protocolos obsoletos. SMBv1 carecía de los mecanismos modernos de seguridad presentes en SMBv3 (como cifrado robusto y validaciones estrictas). Mantenerlo activo por simple compatibilidad hacia atrás en la red expuso a millones de máquinas a la ejecución de código no autenticado.

Microsoft emitió el boletín MS17-010 semanas antes de los ciberataques globales. La devastación posterior demostró que, desde la perspectiva del *Blue Team*, la rapidez y eficacia en el despliegue de actualizaciones críticas de seguridad (incluso parcheando sistemas fuera de soporte) es el pilar absoluto de la defensa corporativa.

El éxito de la rápida propagación del *malware* post-explotación se debió a redes internas planas. Una arquitectura de red bien segmentada, con reglas que bloqueen el tráfico SMB (puertos 445 y 139) entre estaciones de trabajo que no necesitan comunicarse entre sí, detiene el movimiento lateral (*Lateral Movement*), conteniendo la brecha de forma efectiva.

Desde la perspectiva del *Red Team* y la inteligencia de amenazas, la filtración de herramientas avanzadas demostró que el descubrimiento de vulnerabilidades *Zero-Day* a nivel de kernel, cuando caen en el dominio público, cambian el panorama de amenazas de la noche a la mañana. La democratización de estas herramientas elevó drásticamente el nivel técnico necesario para defender infraestructuras modernas.

Bibliografía:

- Wikipedia. (2025). *Arquitectura de Windows NT.* Wikipedia.org. Recuperado el 01 de marzo de 2026 de https://es.wikipedia.org/wiki/Arquitectura_de_Windows_NT
- Wikipedia. (2026). *Windows NT*. Wikipedia.org. Recuperado el 01 de marzo de 2026 de https://es.wikipedia.org/wiki/Windows_NT
- NIST. (2017). *NVD-CVE-2017-0144.* NIST-National Vulnerability Database. Recuperado el 02 de marzo de 2026 de https://nvd.nist.gov/vuln/detail/CVE-2017-0144
- CodeLucky. (2025). *Windows NT Kernel: Complete Guide to Design, Architecture and Implementation*. CodeLucky. Recuperado el 02 de marzo de 2026 de https://codelucky.com/windows-nt-kernel-design/

- Mhopkins-Msft. (2026). *Modo de usuario y modo kernel - Windows drivers*. Microsoft Learn. Recuperado el 02 de marzo de 2026 de https://learn.microsoft.com/es-es/windows-hardware/drivers/gettingstarted/user-mode-and-kernel-mode

- Shivanandhan, M. (2023). *EternalBlue Explained – An In-Depth Analysis of the Notorious Windows Flaw*. freeCodeCamp.org. Recuperado el 02 de marzo de 2026 de https://www.freecodecamp.org/news/eternalblue-explained-an-analysis-of-the-windows-flaw/

- BetaFred. (2017). *Microsoft Security Bulletin MS17-010 - Critical*. Microsoft Learn. Recuperado el 02 de marzo de 2026 de https://learn.microsoft.com/en-us/security-updates/Securitybulletins/2017/ms17-010